Cuidarte+

Aseguramiento de calidad, seguridad y cumplimiento

- EP4 · Defensa individual · ISY1102 · Sección 002v
- Antonella Cuvertino y Miriam Hammami
- Decisión sustentada: NO CERTIFICADO para producción

Un sistema clínico exige más que funcionar

Contexto, arquitectura y riesgo

- React SPA → API Express → PostgreSQL
- Administrador, médico y paciente; acceso anónimo limitado
- Prioridad: evitar exposición, privilegios indebidos y pérdida clínica

Estrategia basada en riesgos

IE2 · Seguridad y normativa desde la planificación

- Shift-Left: requisitos → riesgos → casos → evidencia
- Primero autorización y credenciales; después persistencia y rendimiento
- Entrada: ambiente aislado. Salida: cero críticos o graves abiertos

Tipos de prueba: qué comprueba cada uno

IE4 · Origen del caso e impacto

- Funcional: login válido e inválido → continuidad de acceso
- Integración: API + base + PDF → persistencia e integridad
- Seguridad: JWT, IDOR y roles → confidencialidad y privilegios
- Rendimiento: consulta y carga breve → tiempo de atención

Casos definidos y trazabilidad

IE4 / IE8 · Del requisito al defecto

- 8 casos maestros; 12 checkpoints API derivados
- RF-3.3 → CP-FUNC-003 → CP-API-007 → DEF-003
- Esperado: conservar fila. Obtenido: cero filas tras DELETE
- SQLi y WCAG completos permanecen pendientes

Herramientas y ambiente reproducible

Elección y límites de cada herramienta

- Node.js fetch + PostgreSQL: peticiones y verificación de persistencia
- SonarQube + escáner oficial: análisis estático exportado
- Docker: base aislada; navegador: evidencia visual
- Jest, DAST, JMeter sostenido y WCAG: ampliaciones pendientes

Ejecución: 12 comprobaciones reales

IE8 · Resultado, evidencia y alcance

- 6 PASS: login, inválidos, validación, IDOR, JWT y PDF
- 6 FAIL: persistencia, hash, auditoría, roles, latencia y borrado anónimo
- Evidencia: JSON por caso, CSV, consultas y capturas
- Los 5 PASS de UI del PDF anterior son antecedentes históricos

Defectos que bloquean el lanzamiento

IE4 / IE10 · Clasificación por impacto

- CRÍTICO: médico se asigna administrador (HTTP 200)
- CRÍTICO: DELETE de usuario sin sesión elimina la cuenta
- GRAVES: contraseñas, borrado físico, auditoría y latencia
- Sin correcciones ni retest de cierre: todos siguen abiertos

SonarQube: interpretar, no solo contar

IE6 · Análisis estático y comparación con criterios

- Bugs: 1 · Vulnerabilities: 0 · Hotspots: 3 · Smells: 72
- Quality Gate: OK · Coverage: 0.0%
- Hotspot ≠ vulnerabilidad confirmada; requiere revisión
- No se confirma la SQLi del controlador inexistente del encargo

Rendimiento y privacidad

IE6 · Lo medido y la norma aplicable

- 200 solicitudes simultáneas · p95 8698 ms · objetivo <300 ms
- 0 errores HTTP; lote breve, sin acreditar estabilidad sostenida
- Ley 19.628: datos de salud y tratamiento indebido
- Ley 21.719: vigencia general desde 01-12-2026; Ley 21.663 según ámbito

Recomendaciones con evidencia

IE10 · Corregir y volver a comprobar

- 1. Autorizar antes de mutar; cambios de rol solo por administrador
- 2. Hash adaptativo, soft delete y auditoría transaccional
- 3. Retirar demoras y ejecutar retest + regresión
- 4. Completar ERS, cobertura, DAST, WCAG y carga sostenida

Dictamen: NO CERTIFICADO

La evidencia no cumple los criterios de salida

- 2 defectos críticos y 4 graves abiertos
- Reevaluar después de remediar, retestar y completar el alcance
- Expediente: informe oficial, actividades, evidencias y código
- Defensa individual: comprender cada dato y cada limitación

Evidencia A · Ejecución real de API

Cuidarte+ · Ejecución real de API

20 de octubre de 2026 · Base aislada · Datos sintéticos · Runner Node.js

12 checkpoints · 6 PASS · 6 FAIL

Caso	Comprobación	Estado	Obtenido
CP-API-001	Login válido y JWT	PASS	HTTP 200; firma válida=true
CP-API-002	Credenciales inválidas	PASS	HTTP 401
CP-API-003	Campos obligatorios de examen	PASS	HTTP 400
CP-API-004	IDOR por paciente ajeno	PASS	HTTP 403
CP-API-005	JWT alterado y vencido	PASS	Alterado 401; vencido 401
CP-API-006	Registro y adjunto PDF	PASS	Crear 201; subir 201; propio 200; ajeno 403
CP-API-007	Persistencia de borrado lógico	FAIL	HTTP 200; filas persistidas=0
CP-API-008	Contraseña con hash adaptativo	FAIL	Formato bcrypt=false; igualdad con entrada=true
CP-API-009	Auditoría de cambio de rol con origen	FAIL	HTTP 400; columnas=id, usuario_id, accion, fecha_hora
CP-API-010	Médico no puede asignarse administrador	FAIL	HTTP 400; roles=medico
CP-API-011	Latencia de consulta menor de 300 ms	FAIL	HTTP 200; 5120 ms
CP-API-012	Eliminar usuario sin autenticar	FAIL	HTTP 200; filas restantes=0

Fuente: resultados_api.json. Captura de un resumen generado desde evidencia; no es una pantalla de Cuidarte+ ni de SonarQube.

Evidencia B · Resumen de exportación real de SonarQube

Cuidarte+ · Resultado de análisis estático

Resumen generado desde la exportación API real de SonarQube; no es captura de su interfaz.

Bugs	Vulnerabilities	Security Hotspots
1	0	3

Code Smells	Coverage (%)	Líneas de código
72	0.0	10133

Quality Gate: OK | Servidor: 9.9.8.100196

Hotspots requieren revisión; cobertura sin LCOV no acredita pruebas instrumentadas.

Fuentes: metricas.json, quality_gate.json y servidor.json. Proyecto: isy1102-cuidarte.

20 de octubre de 2026 · Entorno local académico · Dictamen QA: NO CERTIFICADO.